

LUIZA DE FARIA BASTOS RIBEIRO
MARIA FERNANDA CAETANO
PEDRO HENRIQUE MOREIRA MONTES

**POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO
APLICADAS AO CENÁRIO DE CENTRO HOSPITALAR
DIGITAL**

Araquari

08 de junho de 2026

LUIZA DE FARIA BASTOS RIBEIRO
MARIA FERNANDA CAETANO
PEDRO HENRIQUE MOREIRA MONTES

POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO APLICADAS AO CENÁRIO DE CENTRO HOSPITALAR DIGITAL

Relatório apresentado como requisito da disciplina de Segurança da Informação, ministrada pelo professor Mehran Misaghi, no curso de Bacharelado em Sistemas de Informação, no Instituto Federal Catarinense – Campus Araquari.

Araquari

08 de junho de 2026

SUMÁRIO

1. INTRODUÇÃO.....	5
1.1. Vida Plena.....	5
Figura 01 – Recepção do Centro Hospitalar Vida Plena.....	5
1.2. Sistemas Integrados.....	6
2. OBJETIVO.....	6
3. METODOLOGIA.....	6
4. CLASSIFICAÇÃO.....	6
4.1 Classificação da Informação.....	7
4.2. Mapa de Riscos.....	8
5. POLÍTICA DE SEGURANÇA DA INFORMAÇÃO.....	10
5.1 CONTROLE DE ACESSO POR PERFIL (LUIZA).....	10
5.1.2 Informações Gerais.....	10
5.1.3 Diretrizes.....	10
5.1.4 Perfis de Acesso, suas responsabilidades e restrições.....	11
5.1.4.1 Médico.....	11
5.1.4.2 Enfermeiro(a).....	11
5.1.4.3 Administrativo.....	11
5.1.5 Periodicidade.....	12
5.1.6 Tratamento de Violações.....	12
5.1.7 Penalidades.....	13
5.1.7.1 Infrações Leves.....	13
5.1.7.2 Infrações Moderadas.....	13
5.1.7.3 Infrações Graves.....	13
5.2 ARMAZENAMENTO SEGURO DE DADOS SENSÍVEIS (LUIZA).....	14
5.2.1 Finalidade.....	14
5.2.2 Informações Gerais.....	14
5.2.3 Diretrizes.....	14
5.2.3.1 Proteção dos Dados em Repouso.....	14
5.2.3.2 Proteção dos Dados em Trânsito.....	14
5.2.4 Política de backup.....	15
5.2.4.1 Frequência.....	15
5.2.4.2 Armazenamento.....	15
5.2.4.3 Testes de Recuperação.....	15
5.2.5 Tratamento de Incidentes.....	15
5.2.6 Penalidades.....	16
5.2.6.1 Infrações Leves.....	16
5.2.6.2 Infrações Moderadas.....	16
5.2.6.3 Infrações Graves.....	16
4.3 DESCARTE DIGITAL DE PRONTUÁRIOS ANTIGOS (PEDRO).....	17
4.3.1 Finalidade.....	17
4.3.2 Risco Identificado.....	17
4.3.5 - Penalidades.....	17
5.4 POLÍTICA DE TROCA DE SENHA OBRIGATÓRIA (PEDRO).....	18

5.4.1 Finalidade.....	18
5.4.2 Diretrizes.....	18
5.4.3 Requisitos.....	18
5.4.4 Periodicidade.....	18
5.4.5 Autenticação Multifator.....	19
5.4.6 Penalidades.....	19
5.4.7 Autoria.....	19
5.4.8 Risco Identificado.....	19
4.4.9 Diretrizes.....	19
5.5.10 Responsabilidades.....	20
5.5 RESTRIÇÃO DE USO DE REDES SOCIAIS EM ÁREAS CRÍTICAS.....	20
5.5.1 Finalidade.....	20
5.5.2 Informações Gerais.....	20
5.5.3 Áreas Críticas.....	20
5.5.4 Risco Identificado.....	21
5.5.5 Diretrizes.....	21
5.5.6 Responsabilidades.....	21
5.5.6.1 Médicos.....	21
5.5.6.2 Enfermeiros(as).....	21
5.5.6.4 Setor de Tecnologia da Informação.....	22
5.5.6.5 Supervisores e Gestores.....	22
5.5.7 Penalidades.....	22
5.6 RESTRIÇÃO DE USO DE REDES SOCIAIS EM OUTRAS ÁREAS.....	23
5.6.1 Finalidade.....	23
5.6.2 Informações Gerais.....	23
5.6.3 Risco Identificado.....	23
5.6.4 Diretrizes.....	23
5.6.5 Responsabilidades.....	24
5.6.5.1 Médicos.....	24
5.6.5.2 Enfermeiros(as).....	24
5.6.5.3 Colaboradores Administrativos.....	24
5.6.5.4 Setor de Tecnologia da Informação.....	24
5.6.5.5 Recursos Humanos.....	24
5.6.5.6 Supervisores e Gestores.....	24
5.6.6 Penalidades.....	24
6. TRATAMENTO DE INCIDENTES DE SEGURANÇA.....	25
6.1 VAZAMENTO DE DADOS DE PACIENTES.....	25
6.1.1 Procedimentos.....	25
6.1.2 Penalidades.....	25
6.2 ACESSO INDEVIDO POR FUNCIONÁRIOS (DIGITAL).....	26
6.2.1 Procedimentos.....	26
6.2.2 Penalidades.....	26
6.3 ACESSO INDEVIDO POR FUNCIONÁRIOS (FÍSICO).....	26
6.3.1 Procedimentos.....	27

6.3.2 Penalidades.....	27
6.4 USO INDEVIDO DE REDES SOCIAIS EM AMBIENTE CLÍNICO.....	27
6.4.1 Procedimentos.....	27
6.4.2 Penalidades.....	27
7. TREINAMENTO E CONSCIENTIZAÇÃO.....	28
8. REVISÃO DA POLÍTICA.....	28
REFERÊNCIAS.....	29
ANEXO A.....	30
A.1 Cenário do Hospital.....	30
A.2 Leitura e Interpretação das Normas.....	30
A.3 Revisão da Política.....	30
A.4 Definição de Penalidades.....	31
A.5 Mapa de Riscos.....	31
A.6 Sessões Introdutórias.....	31
Partes geradas por IA:.....	31
Imagens geradas por IA:.....	31

1. INTRODUÇÃO

O Vida Plena é um Centro Hospitalar Digital (CHD), de assistência privada, que oferece várias especialidades. É capaz de conectar exames, históricos e prontuários eletrônicos para que médicos e enfermeiros possam tomar decisões rápidas, e que pacientes possam ter acesso remoto à seu histórico de exames, consultas e afins.

Dentro do ambiente hospitalar, diversas variáveis podem ser ameaças invisíveis e perigosas, capazes de destruir a confiança que o paciente deposita no hospital ou, nos piores cenários, colocar em risco a vida e a integridade dos pacientes. Por isso é necessário ter cuidado com o vazamento de informações, o compartilhamento de senhas, os acessos não autorizados, o uso inadequado de redes sociais, entre outros.

É por isso que a segurança da informação é indispensável. Este trabalho apresenta um guia de boas práticas e políticas projetadas para a realidade do CHD. Abordamos desde quem pode ver cada tipo de dado até a forma correta de descartar prontuários e reagir a incidentes.

1.1. Vida Plena

O Centro Hospitalar Vida Plena é um centro de saúde privada localizado em Joinville. A empresa tem 420 funcionários e 180 leitos à disposição 24 horas aos pacientes. Ele oferece atendimento de emergência, internação hospitalar, centro cirúrgico, UTI adulto e neonatal, maternidade, exames laboratoriais, diagnósticos por imagem e consultas ambulatoriais.

- **Visão:** Oferecer atendimento de excelência, com tecnologia, segurança e humanização.
- **Missão:** Ser referência em saúde privada na região norte de Santa Catarina.
- **Valores:** Humanização, Ética, Segurança, Qualidade e Inovação.

Figura 01 – Recepção do Centro Hospitalar Vida Plena



1.2. Sistemas Integrados

O Centro Hospitalar Digital conta com uma rede interna que abriga alguns sistemas integrados que podem ser acessados pelos colaboradores, a fim de poder facilitar o acesso dos profissionais nos atendimentos, em situações que necessitam de resposta rápida, emergencial ou no dia-a-dia das consultas.

- **Sistema Hospitalar (ERP):** Cadastro de pacientes, agendamento de consultas, controle de internações, gestão financeira e de convênios;
- **Prontuário Eletrônico:** Registro de histórico clínico, prescrições médicas, evolução dos pacientes e resultados de exames;
- **Sistema de Laboratório:** Solicitação de exames, controle de amostras e emissão de laudos;
- **Sistema de Gestão de Pessoas:** Folhas de pagamento, controle de ponto, gestão de férias, treinamentos, demissões e admissões;
- **Sistema de BI (Business Intelligence):** Indicadores hospitalares, taxa de ocupação, tempo médio de atendimento e custos operacionais.

2. OBJETIVO

Aplicar os conceitos de gestão de riscos, segurança da informação e proteção da privacidade estudados na disciplina para elaborar políticas adequadas ao cenário do Centro Hospitalar Digital (CHD). As políticas propostas visam identificar, tratar e mitigar os riscos descritos no enunciado, estabelecendo diretrizes para a proteção dos dados dos pacientes, o controle de acesso aos sistemas e a utilização segura dos recursos tecnológicos disponíveis no ambiente analisado.

3. METODOLOGIA

Para a elaboração das políticas apresentadas neste trabalho, foram analisadas as normas ABNT NBR ISO 31000:2018, ABNT NBR ISO/IEC 27005:2023 e ABNT NBR ISO/IEC 27557:2023, disponibilizadas pelo professor da disciplina, bem como os materiais e conceitos abordados em sala de aula. Com base nos princípios de gestão de riscos, segurança da informação e proteção da privacidade estabelecidos por essas referências, foram desenvolvidas as políticas necessárias para atender aos requisitos do cenário proposto, contemplando os riscos e controles especificados no enunciado da atividade.

4. CLASSIFICAÇÃO

Para melhor definir as políticas, é interessante que haja uma classificação da informação, dessa forma podendo visualizar os procedimentos de forma mais clara. Ademais, também é interessante que haja um mapa de riscos, que seja bem estruturado e contemple os principais ativos críticos do hospital. As seções deste capítulo apresentam essas informações.

4.1 Classificação da Informação

Foram agrupadas as informações referentes ao cenário hospitalar em 05 categorias, a fim de realizar uma apresentação resumida neste documento. As categorias tratam de informações públicas, informações internas, informações confidenciais, informações restritas e informações estratégicas e de segurança institucional. Elas serão descritas a seguir:

- **Informação Pública:** informações destinadas à divulgação para pacientes e sociedade, trata-se da história do hospital, missão, visão, valores, organograma institucional, horários de funcionamento, telefones de contato, localização, campanhas de prevenção, notícias, eventos, redes sociais e informações afins.
 - **Tipo de dado:** informações institucionais;
 - **Impacto de Vazar:** : baixo, pois são informações de acesso público;
 - **Classificação:** público;
 - **Regra de Compartilhamento:** Pode ser compartilhada livremente com qualquer pessoa, sobre cuidados cabíveis de disseminação de fake news diante de alterações mal intencionadas.

- **Informação Interna:** informações utilizadas na rotina administrativa e operacional hospitalar, trata-se de atas de reuniões, comunicados internos, organograma funcional, escalas de trabalho, procedimentos operacionais, fluxos de atendimento, cronograma de treinamentos, programação de férias, informativos internos e informações afins.
 - **Tipo de dado:** informações de uso interno.
 - **Impacto de Vazar:** baixo a moderado, podendo afetar processos internos;
 - **Classificação:** Interno
 - **Regra de Compartilhamento:** Somente colaboradores autorizados dentro do ambiente hospitalar físico ou digital.

- **Informação Confidencial:** dados pessoais e informações estratégicas, trata-se de cadastro dos pacientes (CPF, RG, endereços, contatos, informações sobre convênios e afins), faturamento hospitalar, contratos com fornecedores, relatórios financeiros, planejamento estratégico, relatórios gerenciais, auditorias internas e informações afins;
 - **Tipo de dado:** dados pessoais e informações estratégicas;
 - **Impacto de Vazar:** alto, podendo gerar prejuízos ao hospital e aos titulares dos dados;
 - **Classificação:** confidencial;
 - **Regra de Compartilhamento:** acesso restrito apenas aos profissionais autorizados e conforme a necessidade de suas funções.

- **Informação Confidencial:** informações críticas para a operação e segurança do hospital, trata-se de histórico clínico de pacientes, diagnósticos, exames laboratoriais, laudos médicos, prescrições e evolução clínica, senhas administrativas, chaves criptográficas, tokens de autenticação, certificados digitais, backups completos ou parciais, configurações de servidores, diagrama de rede, plano de recuperação de desastres, relatórios de vulnerabilidades, plano de resposta de incidentes e informações afins.
 - **Tipo de dado:** dados sensíveis e credenciais críticas;
 - **Impacto de Vazar:** muito alto, podendo comprometer a segurança da instituição e a privacidade dos pacientes;
 - **Classificação:** restrito;
 - **Regra de Compartilhamento:** acesso altamente restrito, mediante autenticação forte, controle de acesso por perfil, criptografia e registro de auditoria.

4.2. Mapa de Riscos

A seguir, é apresentado o mapa de riscos do cenário hospitalar.

Ativo	Risco Identificado	Controles Aplicados
Dados Sensíveis dos Pacientes	Vazamento ou divulgação indevida dos dados	Criptografia AES-256, TLS 1.3, Controle de Acesso por Perfil, Auditoria, Monitoramento contínuo e Classificação da Informação
Prontuários Eletrônicos	Acesso não autorizado, alteração indevida ou indisponibilidade dos registros	RBAC, MFA, Gestão de Senhas, Logs de Auditoria, Controle de Sessão e Trilhas de Auditoria
Usuários (Médicos, Enfermeiros e Administrativos)	Compartilhamento de credenciais, engenharia social e uso indevido dos sistemas	Política de Senhas, MFA, Treinamentos periódicos, Campanhas de Conscientização e Auditoria de acessos
Redes Sociais e Dispositivos Móveis	Exposição indevida de informações e vazamento de dados	Política de Uso Aceitável, MDM (Gerenciamento de Dispositivos Móveis), Monitoramento, Conscientização e Restrição de compartilhamentos

Sistemas Integrados	Integrações inseguras ou comprometidas, e interceptação de dados	TLS 1.3, Autenticação Forte, APIs Seguras, Monitoramento, Gestão de Riscos de Terceiros e Testes de Segurança
Infraestrutura Tecnológica	Interrupção dos serviços, perda ou corrupção de dados e indisponibilidade do ambiente	Backups criptografados, Plano de Recuperação de Desastres (DRP), Plano de Continuidade de Negócios (PCN), Redundância e Monitoramento contínuo
Queda de Energia	Interrupção crítica das operações hospitalares, indisponibilidade dos sistemas de prontuário eletrônico (PEP), perda de dados em trânsito (não salvos), falha em dispositivos médicos conectados à rede e isolamento do centro digital por queda dos ativos de rede.	Geradores redundantes (combustível), Nobreaks (UPS) de dupla conversão, contratos de manutenção preventiva e monitoramento automatizado de carga.

5. POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Neste capítulo, apresentamos as políticas de segurança criadas sob medida para a realidade do Centro Hospitalar Digital (CHD). Cada procedimento aqui especificado define responsabilidades, cuidados práticos e consequências, a fim de proteger a privacidade dos pacientes e garantir que as informações médicas estejam sempre seguras, íntegras e disponíveis para quem precisa.

5.1 CONTROLE DE ACESSO POR PERFIL (LUIZA)

5.1.1 Finalidade

Garantir que o acesso às informações e aos sistemas do Centro Hospitalar Digital (CHD) seja realizado de forma segura, controlada e compatível com as responsabilidades de cada colaborador, assegurando a confidencialidade, integridade e disponibilidade dos dados dos pacientes.

5.1.2 Informações Gerais

- **Autoria:** Comitê de Segurança da Informação;
- **Data:** 01 de Junho de 2026;
- **Versão:** Versão 1.0;
- **Aprovação:** Diretoria Geral do Centro Hospitalar Digital;
- **Vigência:**
 - **Início:** 01 de Junho de 2026;
 - **Término:** 01 de Junho de 2028;

5.1.3 Diretrizes

- O acesso aos sistemas do CHD será concedido de acordo com o cargo, função e necessidade operacional do colaborador;
- As permissões serão definidas pelo setor de Tecnologia da Informação em conjunto com a gestão responsável pela área solicitante;
- Qualquer solicitação de criação, alteração ou remoção de acesso deverá ser formalizada e aprovada pelo gestor imediato;
- Os usuários terão acesso apenas aos dados necessários para o desempenho de suas funções;
- É vedado o acesso a informações sem justificativa profissional ou clínica;
- Consultas realizadas por mera curiosidade ou interesse pessoal serão consideradas infrações graves;
- Cada colaborador receberá uma conta de acesso única e intransferível;
- Todos os usuários são responsáveis pelas atividades executadas por meio de suas credenciais.

5.1.4 Perfis de Acesso, suas responsabilidades e restrições

5.1.4.1 Médico

Os médicos possuem acesso aos sistemas clínicos necessários para diagnóstico, tratamento e acompanhamento dos pacientes sob sua responsabilidade.

Permissões

- Consultar prontuários eletrônicos;
- Registrar evoluções médicas;
- Solicitar exames laboratoriais e de imagem;
- Consultar resultados de exames;
- Emitir prescrições eletrônicas;
- Registrar diagnósticos;
- Solicitar internações e altas médicas;
- Realizar acesso remoto autorizado mediante autenticação multifator.

Restrições

- Não acessar prontuários de pacientes sem vínculo assistencial;
- Não compartilhar informações médicas com pessoas não autorizadas;
- Não utilizar dispositivos pessoais sem autorização da instituição.

5.1.4.2 Enfermeiro(a)

Os profissionais de enfermagem possuem acesso às informações necessárias para a prestação da assistência ao paciente.

Permissões

- Consultar dados clínicos pertinentes ao atendimento;
- Registrar evoluções de enfermagem;
- Registrar sinais vitais;
- Consultar prescrições médicas;
- Registrar procedimentos realizados;
- Atualizar informações assistenciais sob sua responsabilidade.

Restrições

- Não alterar diagnósticos médicos;
- Não emitir prescrições;
- Não excluir registros clínicos;
- Não acessar informações administrativas sem autorização.

5.1.4.3 Administrativo

Os colaboradores administrativos possuem acesso apenas aos sistemas relacionados às suas atividades operacionais.

Permissões

- Consultar dados cadastrais dos pacientes;
- Realizar agendamentos;
- Gerenciar autorizações e convênios;
- Consultar informações financeiras necessárias ao faturamento;
- Emitir documentos administrativos.

Restrições

- Não acessar prontuários médicos;
- Não consultar exames clínicos;
- Não visualizar diagnósticos ou prescrições;
- Não alterar informações clínicas dos pacientes.

5.1.5 Periodicidade

Os acessos concedidos serão revisados periodicamente. A cada três meses serão realizadas auditorias para verificar:

- Usuários ativos;
- Permissões concedidas;
- Necessidade de manutenção dos acessos;
- Contas inativas;
- Colaboradores desligados ou com alteração de função.

Monitoramento e Auditoria

Todos os acessos aos sistemas serão registrados automaticamente em logs de auditoria contendo:

- * Nome do usuário;
- * Data e horário do acesso;
- * Endereço IP utilizado;
- * Sistema acessado;
- * Operação realizada;
- * Dados consultados ou alterados.

Os registros serão mantidos pelo prazo definido pela legislação e pelas políticas internas da instituição.

O CHD poderá realizar auditorias periódicas para identificar acessos suspeitos, não autorizados ou incompatíveis com as atividades desempenhadas pelo colaborador.

5.1.6 Tratamento de Violações

Será considerada violação desta política qualquer tentativa de:

- Acessar informações sem autorização;
- Compartilhar credenciais;
- Burlar controles de segurança;
- Consultar dados de pacientes sem necessidade profissional;
- Utilizar privilégios indevidamente.

Toda ocorrência será investigada pelo Comitê de Segurança da Informação.

5.1.7 Penalidades

As penalidades serão aplicadas de acordo com a gravidade da infração, respeitando as normas internas da instituição e a legislação vigente.

5.1.7.1 Infrações Leves

Exemplos:

- Não bloquear a estação de trabalho ao se ausentar;
- Descumprimento ocasional de procedimentos de acesso.

Penalidade:

- Orientação formal;
- Treinamento obrigatório;
- Advertência escrita.

5.1.7.2 Infrações Moderadas

Exemplos:

- Compartilhamento de credenciais;
- Utilização indevida de sistemas sem causar prejuízo.

Penalidade:

- Advertência formal;
- Suspensão de até 15 dias;
- Restrição temporária de acesso.

5.1.7.3 Infrações Graves

Exemplos:

- Consulta de prontuários sem autorização;
- Vazamento de informações;
- Uso de credenciais de terceiros;
- Alteração indevida de registros clínicos.

Penalidade:

- Suspensão imediata;
- Desligamento por justa causa;
- Responsabilização civil, administrativa e criminal;
- Comunicação às autoridades competentes, quando aplicável.

5.2 ARMAZENAMENTO SEGURO DE DADOS SENSÍVEIS (LUIZA)

5.2.1 Finalidade

Garantir a confidencialidade, integridade, disponibilidade e autenticidade dos dados sensíveis dos pacientes armazenados pelo Centro Hospitalar Digital (CHD), protegendo-os contra acessos não autorizados, perda, alteração indevida, vazamento ou destruição acidental. Esta política aplica-se a todos os sistemas, servidores, bancos de dados, dispositivos móveis, estações de trabalho, serviços em nuvem e mídias de armazenamento utilizados pelo CHD.

5.2.2 Informações Gerais

- **Autoria:** Comitê de Segurança da Informação;
- **Data:** 01 de Junho de 2026;
- **Versão:** Versão 1.0;
- **Aprovação:** Diretoria Geral do Centro Hospitalar Digital;
- **Vigência:**
 - **Início:** 01 de Junho de 2026;
 - **Término:** 01 de Junho de 2028;

5.2.3 Diretrizes

5.2.3.1 Proteção dos Dados em Repouso

Todos os dados armazenados em:

- Bancos de dados;
- Servidores locais;
- Sistemas de backup;
- Dispositivos de armazenamento externo;
- Ambientes de nuvem;

Deverão utilizar criptografia AES-256 (Advanced Encryption Standard com chave de 256 bits).

A criptografia deverá permanecer ativa durante todo o ciclo de vida das informações.

5.2.3.2 Proteção dos Dados em Trânsito

Toda transmissão de informações entre:

- Sistemas internos;
- Aplicações web;
- Equipamentos médicos integrados;

- Usuários remotos;
- Serviços em nuvem;

Deverá utilizar protocolos seguros com criptografia TLS 1.3 ou superior.

É proibida a transmissão de dados clínicos por:

- E-mail pessoal;
- Aplicativos de mensagens não autorizados;
- Dispositivos sem proteção adequada.

5.2.4 Política de backup

5.2.4.1 Frequência

Serão realizados:

- Backups incrementais diários;
- Backups completos semanais;
- Backups mensais para retenção de longo prazo.

5.2.4.2 Armazenamento

Os backups deverão:

- Permanecer criptografados;
- Ser armazenados em local fisicamente distinto do ambiente principal;
- Possuir cópia de contingência em ambiente seguro ou nuvem corporativa.

5.2.4.3 Testes de Recuperação

A equipe de TI realizará testes periódicos de restauração para verificar:

- Integridade dos arquivos;
- Funcionalidade dos backups;
- Tempo de recuperação dos sistemas.

Os testes devem ocorrer, no mínimo, a cada seis meses.

5.2.5 Tratamento de Incidentes

Caso seja identificado:

- Vazamento de dados;
- Tentativa de invasão;
- Acesso não autorizado;
- Alteração indevida de informações;

A equipe de Segurança da Informação deverá ser acionada imediatamente para:

- Conter o incidente;
- Preservar evidências;
- Investigar as causas;

- Avaliar os impactos;
- Adotar medidas corretivas;
- Notificar as autoridades competentes quando exigido pela legislação.

5.2.6 Penalidades

5.2.6.1 Infrações Leves

Exemplos:

- Armazenamento inadequado de arquivos sem causar exposição de dados;
- Descumprimento de procedimentos internos.

Penalidades:

- Orientação formal;
- Treinamento obrigatório;
- Advertência escrita.

5.2.6.2 Infrações Moderadas

Exemplos:

- Compartilhamento indevido de arquivos protegidos;
- Utilização de dispositivos não autorizados.

Penalidades:

- Advertência formal;
- Suspensão temporária;
- Restrição de acessos.

5.2.6.3 Infrações Graves

Exemplos:

- Vazamento de dados de pacientes;
- Manipulação indevida de informações clínicas;
- Cópia ou extração não autorizada de dados.

Penalidades:

- Suspensão imediata;
- Desligamento por justa causa;
- Responsabilização civil, administrativa e criminal.

4.3 DESCARTE DIGITAL DE PRONTUÁRIOS ANTIGOS (PEDRO)

4.3.1 Finalidade

Garantir a eliminação segura de prontuários eletrônicos após o término do prazo legal de retenção, evitando vazamentos de informações médicas e reduzindo riscos de privacidade dos pacientes.

- **Autoria:** Comitê de Segurança da Informação;
- **Data:** 01/06/2026
- **Versão:** 1.0
- **Diretoria Geral do CHD**
- **Vigência:** 01/06/2026
- **Início:** 01/06/2026
- **Término:** 01/06/2028

4.3.2 Risco Identificado

- **Risco:** Recuperação indevida de prontuários descartados.
- **Probabilidade:** Média
- **Impacto:** Muito Alto
- **Classificação:** Crítico

4.3.4 Diretrizes

- O descarte somente poderá ocorrer após o cumprimento do prazo legal de armazenamento.
- Os registros deverão ser removidos utilizando métodos de exclusão segura.
- Backups contendo os dados descartados deverão ser eliminados.
- Todo descarte deverá ser documentado.
- O processo deverá ser auditado periodicamente.
- O descarte deverá ser autorizado formalmente pela Diretoria Clínica e pelo setor de TI.

4.3.4 - Responsabilidades

- Setor de TI
- Executar o descarte seguro.
- Registrar evidências do processo.
- Diretoria Clínica
- Autorizar a eliminação dos registros.
- Auditoria Interna
- Verificar a conformidade do procedimento.

4.3.5 - Penalidades

O descarte não autorizado ou inadequado de prontuários poderá resultar em:

- Advertência verbal;
- Advertência escrita;
- Suspensão;
- Demissão por justa causa;
- Responsabilização civil, administrativa e criminal.

5.4 POLÍTICA DE TROCA DE SENHA OBRIGATÓRIA (PEDRO)

5.4.1 Finalidade

- Proteger os sistemas hospitalares contra acessos não autorizados e reduzir riscos decorrentes do comprometimento de credenciais.
- Reduzir riscos relacionados ao comprometimento de credenciais

5.4.2 Diretrizes

- Senhas devem possuir no mínimo 12 caracteres.
- Devem conter letras maiúsculas, minúsculas, números e caracteres especiais.
- A troca será obrigatória a cada 90 dias.
- É proibida a reutilização das últimas 5 senhas.
- Após 5 tentativas incorretas, a conta será bloqueada.
- O compartilhamento de credenciais é proibido.
- O acesso remoto exigirá autenticação multifator (MFA).

5.4.3 Requisitos

As senhas devem conter:

- Mínimo de 12 caracteres;
- Letras maiúsculas;
- Letras minúsculas;
- Números;
- Caracteres especiais.

5.4.4 Periodicidade

- Troca obrigatória a cada 90 dias.
- Não reutilizar as últimas 5 senhas.

5.4.5 Autenticação Multifator

Obrigatória para:

- Médicos com acesso remoto;
- Administradores de sistemas;
- Usuários com privilégios elevados.

5.4.6 Penalidades

- Compartilhamento de senhas: advertência formal.
- Reincidência: suspensão.
- Uso indevido de credenciais de terceiros: desligamento por justa causa.

5.4.7 Autoria

- Setor de Tecnologia da Informação (TI)
- Data: 08/06/2026
- Versão 1.0
- Aprovação: 08/06/2026
- Diretoria Geral do CHD
- Vigência
- Início: 08/06/2026
- Término: 11/06/2028

5.4.8 Risco Identificado

Risco: Acesso indevido por utilização de credenciais comprometidas.

Probabilidade: Alta

Impacto: Muito Alto

Classificação: Crítico

4.4.9 Diretrizes

- Senhas devem possuir no mínimo 12 caracteres.
- Devem conter letras maiúsculas, minúsculas, números e caracteres especiais.
- A troca será obrigatória a cada 90 dias.
- É proibida a reutilização das últimas 5 senhas.
- Após 5 tentativas incorretas, a conta será bloqueada.
- O compartilhamento de credenciais é proibido.
- O acesso remoto exigirá autenticação multifator (MFA).

5.5.10 Responsabilidades

Colaboradores:

- Manter sigilo das credenciais.

TI:

- Implementar controles de autenticação.
- Monitorar tentativas suspeitas.

Penalidades:

O compartilhamento ou uso indevido de credenciais poderá resultar em:

- Advertência;
- Suspensão;
- Bloqueio da conta;
- Demissão por justa causa em casos graves.
-

5.5 RESTRIÇÃO DE USO DE REDES SOCIAIS EM ÁREAS CRÍTICAS

5.5.1 Finalidade

Estabelecer controles para impedir o uso de redes sociais em áreas críticas do Centro Hospitalar Digital (CHD), visando proteger a privacidade dos pacientes, preservar a segurança das informações institucionais e reduzir riscos operacionais decorrentes de distrações ou da divulgação indevida de dados sensíveis.

5.5.2 Informações Gerais

- **Autoria:** Comitê de Segurança da Informação;
- **Data:** 05 de Junho de 2026;
- **Versão:** Versão 1.0;
- **Aprovação:** Diretoria Geral do Centro Hospitalar Digital;
- **Vigência:**
 - **Início:** 08 de Junho de 2026;
 - **Término:** 11 de Junho de 2027;

5.5.3 Áreas Críticas

Entendem-se como áreas críticas do Centro Hospitalar: Centro Cirúrgico, Unidade de Terapia Intensiva (UTI), Emergência, Laboratórios, Salas de Exames, Centro de Monitoramento, datacenter, áreas de armazenamento e processamento de dados clínicos e quaisquer outras áreas que tenham características ou finalidades semelhantes às citadas nesta seção.

5.5.4 Risco Identificado

O uso de redes sociais em áreas críticas pode levar à divulgação indevida de informações clínicas e exposição de dados sensíveis, além de comprometer as atividades críticas do ambiente hospitalar.

- **Probabilidade:** Média
- **Impacto:** Muito Alto
- **Classificação:** Alto

5.5.5 Diretrizes

- É proibido acessar redes sociais em equipamentos corporativos localizados em áreas críticas;
- É proibido utilizar dispositivos pessoais para acessar redes sociais durante a execução de atividades assistenciais ou procedimentos clínicos;
- Não é permitido fotografar, filmar, gravar áudios ou capturar imagens de pacientes, prontuários, exames, equipamentos ou ambientes clínicos sem autorização formal;
- É proibida a divulgação, em qualquer plataforma digital, de informações relacionadas a pacientes, diagnósticos, tratamentos ou rotinas internas do hospital;
- O acesso às redes sociais será tecnicamente bloqueado na infraestrutura de rede das áreas críticas sempre que possível;
- Exceções somente poderão ocorrer mediante autorização formal da Diretoria e do Comitê de Segurança da Informação;

5.5.6 Responsabilidades

5.5.6.1 Médicos

- Cumprir integralmente as diretrizes desta política durante atendimentos, consultas e procedimentos clínicos;
- Não utilizar redes sociais durante atividades assistenciais em áreas críticas;
- Preservar a confidencialidade das informações dos pacientes acessadas durante o exercício de suas funções;
- Comunicar imediatamente qualquer incidente ou suspeita de exposição indevida de informações.

5.5.6.2 Enfermeiros(as)

- Cumprir integralmente as diretrizes desta política durante a assistência aos pacientes;
- Não utilizar dispositivos móveis para acesso a redes sociais em áreas críticas;

- Garantir a proteção das informações dos pacientes sob sua responsabilidade;
- Reportar situações que representem risco à segurança da informação ou à privacidade dos pacientes.

5.5.6.3 Colaboradores Administrativos

- Cumprir integralmente as diretrizes desta política durante a assistência aos pacientes;
- Respeitar as restrições de acesso às áreas críticas;
- Não registrar ou compartilhar imagens, documentos ou informações relacionadas ao ambiente clínico;
- Preservar a confidencialidade das informações institucionais e dos pacientes às quais tenham acesso;
- Comunicar incidentes ou violações observadas.

5.5.6.4 Setor de Tecnologia da Informação

- Cumprir integralmente as diretrizes desta política durante a assistência aos pacientes;
- Implementar controles técnicos de bloqueio e monitoramento;
- Registrar e investigar tentativas de violação da política;
- Manter os mecanismos de proteção atualizados.

5.5.6.5 Supervisores e Gestores

- Cumprir integralmente as diretrizes desta política durante a assistência aos pacientes;
- Fiscalizar o cumprimento das diretrizes;
- Orientar os colaboradores quanto às regras estabelecidas;
- Reportar imediatamente quaisquer irregularidades identificadas.

5.5.7 Penalidades

O descumprimento desta política por qualquer membro colaborador que acesse o Centro Hospitalar Digital poderá resultar em:

- Advertência Verbal;
- Advertência Escrita;
- Suspensão Disciplinar
- Demissão por justa causa, nos casos previstos na legislação;
- Responsabilização civil, administrativa e criminal quando houver exposição indevida de dados de pacientes ou informações institucionais.

5.6 RESTRIÇÃO DE USO DE REDES SOCIAIS EM OUTRAS ÁREAS

5.6.1 Finalidade

Permitir o uso controlado de redes sociais em áreas administrativas do Centro Hospitalar Digital (CHD), equilibrando a liberdade de utilização pelos colaboradores com a necessidade de preservar a produtividade, a segurança da informação e a privacidade dos pacientes.

5.6.2 Informações Gerais

- **Autoria:** Comitê de Segurança da Informação;
- **Data:** 05 de Junho de 2026;
- **Versão:** Versão 1.0;
- **Aprovação:** Diretoria Geral do Centro Hospitalar Digital;
- **Vigência:**
 - **Início:** 08 de Junho de 2026;
 - **Término:** 11 de Junho de 2027;

5.6.3 Risco Identificado

O uso de redes sociais em áreas comuns pode levar ao compartilhamento indevido de informações institucionais ou dados de pacientes por meio de redes sociais.

- **Probabilidade:** Média
- **Impacto:** Alto
- **Classificação:** Alto

5.6.4 Diretrizes

- O acesso a redes sociais será permitido apenas durante horários de intervalo, descanso ou refeições;
- O uso não poderá comprometer a produtividade, a qualidade do atendimento ou o desempenho das atividades profissionais;
- É proibido divulgar informações internas, estratégicas ou confidenciais do CHD sem autorização formal;
- É proibido publicar ou compartilhar dados de pacientes, imagens de prontuários, exames ou qualquer informação protegida por sigilo profissional;
- É proibido fotografar ou divulgar imagens de áreas clínicas, equipamentos ou documentos institucionais sem autorização;
- O tráfego de rede poderá ser monitorado pelo setor de Tecnologia da Informação para fins de segurança e conformidade;
- O acesso poderá ser restringido ou bloqueado caso sejam identificados riscos à segurança da informação ou ao ambiente de trabalho.

5.6.5 Responsabilidades

5.6.5.1 Médicos

- Utilizar redes sociais apenas nos períodos permitidos e fora das áreas críticas;
- Não divulgar informações relacionadas a pacientes, diagnósticos ou procedimentos realizados no CHD;
- Respeitar as normas de confidencialidade e sigilo profissional.

5.6.5.2 Enfermeiros(as)

- Utilizar redes sociais de forma responsável durante os períodos autorizados;
- Preservar a privacidade dos pacientes e a confidencialidade das informações acessadas;
- Não compartilhar conteúdos relacionados às atividades assistenciais do hospital.

5.6.5.3 Colaboradores Administrativos

- Utilizar redes sociais sem comprometer a produtividade e as atividades profissionais;
- Não divulgar informações internas ou estratégicas da instituição;
- Cumprir as normas de confidencialidade estabelecidas pelo CHD.

5.6.5.4 Setor de Tecnologia da Informação

- Implementar filtros e mecanismos de monitoramento;
- Identificar e reportar incidentes relacionados ao uso inadequado das redes sociais;
- Aplicar controles de acesso quando necessário.

5.6.5.5 Recursos Humanos

- Promover ações de conscientização e treinamento sobre segurança da informação e privacidade;
- Garantir a divulgação adequada desta política aos colaboradores.

5.6.5.6 Supervisores e Gestores

- Fiscalizar o cumprimento das diretrizes;
- Reportar imediatamente quaisquer irregularidades identificadas.

5.6.6 Penalidades

O descumprimento desta política por qualquer membro colaborador que acesse o Centro Hospitalar Digital poderá resultar em:

- Advertência Verbal;
- Advertência Escrita;

- Suspensão temporária de acesso à rede corporativa;
- Suspensão Disciplinar;
- Demissão por justa causa, nos casos previstos na legislação;
- Responsabilização civil, administrativa e criminal quando houver exposição indevida de dados de pacientes ou informações institucionais.

6. TRATAMENTO DE INCIDENTES DE SEGURANÇA

No Centro Hospitalar Digital (CHD), a segurança da informação e a privacidade são tratadas na prática por meio de fluxos claros de identificação, registro, mitigação e resposta a incidentes. Assim que qualquer anomalia ou evento suspeito for detectado, a equipe responsável deve ser acionada imediatamente. A partir desse momento, cada caso deve ser investigado a fundo e documento integralmente.

6.1 VAZAMENTO DE DADOS DE PACIENTES

Considera-se vazamento de dados qualquer divulgação, acesso, compartilhamento ou exposição não autorizada de informações pessoais ou dados sensíveis dos pacientes.

6.1.1 Procedimentos

- Identificar e registrar formalmente o incidente;
- Isolar imediatamente os sistemas, contas ou dispositivos envolvidos;
- Comunicar o incidente ao Setor de Tecnologia da Informação e ao Comitê de Segurança da Informação;
- Preservar evidências para investigação e auditoria;
- Realizar análise dos registros de acesso e das atividades relacionadas ao incidente;
- Avaliar a extensão do vazamento e os possíveis impactos aos titulares dos dados;
- Notificar a Diretoria do CHD e as autoridades competentes quando exigido pela legislação vigente;
- Implementar medidas corretivas e preventivas para evitar recorrências;
- Registrar as lições aprendidas e atualizar os controles de segurança quando necessário.

6.1.2 Penalidades

O colaborador responsável pelo incidente, quando comprovada ação dolosa ou negligência, poderá estar sujeito a:

- Advertência verbal;
- Advertência escrita;
- Suspensão disciplinar;

- Demissão por justa causa;
- Responsabilização civil, administrativa e criminal, conforme a legislação vigente.

6.2 ACESSO INDEVIDO POR FUNCIONÁRIOS (DIGITAL)

Considera-se acesso indevido:

- Consultar prontuários sem necessidade profissional;
- Acessar informações fora do escopo das atribuições do cargo;
- Utilizar credenciais de terceiros;
- Compartilhar informações confidenciais sem autorização;
- Tentar obter acesso não autorizado a sistemas ou dados restritos.

6.2.1 Procedimentos

- Bloqueio imediato da conta ou acesso envolvido;
- Registro formal do incidente;
- Auditoria dos registros de acesso e atividades realizadas;
- Investigação interna conduzida pelo Setor de Tecnologia da Informação e pela gestão responsável do plantão vigente;
- Avaliação do impacto causado à instituição e aos pacientes;
- Aplicação das medidas corretivas necessárias;
- Revisão dos controles de acesso e permissões quando aplicável.

6.2.2 Penalidades

Dependendo da gravidade da ocorrência, poderão ser aplicadas:

- Advertência verbal;
- Advertência escrita;
- Suspensão disciplinar;
- Demissão por justa causa;
- Responsabilização civil, administrativa e criminal, conforme a legislação vigente quando aplicável.

6.3 ACESSO INDEVIDO POR FUNCIONÁRIOS (FÍSICO)

Considera-se acesso indevido:

- Acessar locais de ambientes críticos, descritos na subseção 5.5.3 sobre áreas críticas consideradas;
- Acessar locais ou equipamentos fora do escopo das atribuições do cargo;
- Utilizar credenciais de terceiros para acessar locais de alto risco;
- Tentar obter acesso não autorizado a ambientes críticos não autorizados;

6.3.1 Procedimentos

- Bloqueio imediato das credenciais para entrada de ambientes físicos;
- Registro formal do incidente;
- Auditoria de câmeras e relatos sobre as atividades realizadas dentro dos espaços não autorizados;
- Auditoria interna conduzida pelo responsável de segurança e pela gestão responsável do plantão vigente;
- Avaliação do impacto causado à instituição e aos pacientes;
- Aplicação das medidas corretivas necessárias;
- Revisão dos controles de acesso e permissões quando aplicável.

6.3.2 Penalidades

Dependendo da gravidade da ocorrência, poderão ser aplicadas:

- Advertência verbal;
- Advertência escrita;
- Suspensão disciplinar;
- Demissão por justa causa;
- Responsabilização civil, administrativa e criminal, conforme a legislação vigente quando aplicável.

6.4 USO INDEVIDO DE REDES SOCIAIS EM AMBIENTE CLÍNICO

Consideram-se infrações:

- Publicação de fotos ou vídeos de pacientes;
- Divulgação de diagnósticos, exames ou informações médicas;
- Compartilhamento de imagens de prontuários ou documentos internos;
- Utilização de redes sociais em áreas críticas em desacordo com as políticas estabelecidas;
- Divulgação de informações institucionais sem autorização.

6.4.1 Procedimentos

- Remoção imediata do conteúdo publicado quando possível;
- Registro formal da ocorrência;
- Comunicação à Diretoria e ao Comitê de Segurança da Informação;
- Investigação disciplinar para apuração dos fatos;
- Avaliação dos impactos causados aos pacientes e à instituição;
- Aplicação das medidas corretivas cabíveis.

6.4.2 Penalidades

Dependendo da gravidade da ocorrência, poderão ser aplicadas:

- Advertência verbal;
- Advertência escrita;
- Suspensão disciplinar;
- Demissão por justa causa;
- Responsabilização civil, administrativa e criminal, conforme a legislação vigente.

7. TREINAMENTO E CONSCIENTIZAÇÃO

A conscientização dos colaboradores é considerada um dos principais controles para redução dos riscos relacionados à segurança da informação e à privacidade dos dados. Todos os colaboradores do Centro Hospitalar Digital deverão:

- Participar de treinamentos obrigatórios de segurança da informação e proteção de dados no momento da admissão;
- Participar de reciclagens e treinamentos periódicos, no mínimo uma vez por ano;
- Receber orientações sobre proteção de dados pessoais, privacidade e sigilo profissional;
- Ser capacitados quanto às políticas e procedimentos de segurança adotados pela instituição;
- Assinar Termo de Confidencialidade e Termo de Ciência das Políticas de Segurança da Informação;
- Comunicar incidentes, suspeitas de violação ou situações de risco identificadas durante suas atividades.

8. REVISÃO DA POLÍTICA

Esta Política de Segurança da Informação deverá ser revisada periodicamente para garantir sua adequação às necessidades do Centro Hospitalar Digital (CHD), às exigências legais e aos riscos identificados. As revisões deverão ser aprovadas pela Diretoria Geral e registradas por meio de controle de versões e deverão ser feitas:

- Anualmente;
- Sempre que houver alterações legais ou regulatórias relevantes;
- Em decorrência de mudanças significativas na infraestrutura tecnológica;
- Após incidentes de segurança relevantes;
- Quando forem identificados novos riscos ou vulnerabilidades;
- Sempre que houver alterações nos processos de negócio da instituição.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO 31000:2018: Gestão de riscos — Diretrizes**. Rio de Janeiro: ABNT, 2018.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27005:2023: Segurança da informação, cibersegurança e proteção da privacidade — Orientações para gestão de riscos de segurança da informação**. Rio de Janeiro: ABNT, 2023.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27557:2023: Privacidade da informação e gestão de riscos de privacidade — Diretrizes para gestão de riscos de privacidade**. Rio de Janeiro: ABNT, 2023.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Handbook ABNT NBR ISO 31000:2023: Gestão de riscos — Guia prático para implementação**. Rio de Janeiro: ABNT, 2023.

MISAGHI, Merhan. *Classificação da Informação*. Instituto Federal Catarinense, Segurança da Informação, Araquari, 2026.

MISAGHI, Merhan. *Gestão de Riscos*. Instituto Federal Catarinense, Segurança da Informação, Araquari, 2026.

MISAGHI, Merhan. *Política de Segurança da Informação e Política de Privacidade da Informação*. Instituto Federal Catarinense, Segurança da Informação, Araquari, 2026.

ANEXO A

Este anexo tem a finalidade de mostrar quais as Inteligências Artificiais foram utilizadas para auxiliar a criação deste documento e os *prompt* foram utilizados.

A.1 Cenário do Hospital

O cenário do hospital foi feito utilizando o ChatGPT, pois ele traria informações que estão mais perto da realidade sobre o ambiente hospitalar. Para isso, utilizados dois *prompts*:

- **Imagem:** “Chat, gere uma imagem realista de uma recepção de um hospital moderno e com aparência bem tecnológica. No fundo escreva com letreiro em caixa alta "CENTRO HOSPITALAR VIDA PLENA PRIVADO" e embaixo a frase "Excelência em cuidar de vidas". A imagem gerada foi:



- **Cenário:** “Chat, a partir dessa imagem, poderiam descrever um cenário do centro hospitalar que inclui dados sobre funcionários, leitos, especialidades, sistemas integrados”.

A.2 Leitura e Interpretação das Normas

Auxílio para entender como aplicar as normas dentro do ambiente. Não foi utilizado nenhum prompt específico, apenas perguntas pontuais sobre alguns pontos nas normas para realmente entender como poder aplicar.

A.3 Revisão da Política

Para entender como funciona a revisão da política em um cenário real, principalmente sobre prazos regulares ideais e em que situações seria necessário fazer uma revisão e possível alteração na norma, foi utilizado o ChatGPT.

- **Prompt:** “Chat, como funciona a questão de Revisão de Políticas de Segurança dentro de cenários reais? Com que frequência deve ser feito? Existe alguma situação que eu deveria revisar a norma fora do padrão?”

A.4 Definição de Penalidades

Para entender como funcionam as penalidades dentro de um cenário trabalhista e diante da lei, informamos ao ChatGPT um resumo da política e quais seriam as penalidades cabíveis dentro de cada procedimento.

- **Prompt:** “Chat, baseado no resumo que acabei de informar sobre as políticas que foram criadas para o Centro Hospitalar que você criou, quais seriam as penalidades cabíveis, dentro do cenário trabalhista e penal, para as infrações diante das políticas?”

A.5 Mapa de Riscos

Para apresentar um mapa de riscos mais eficientes, informamos um resumo ao ChatGPT sobre as políticas e pedimos que ele criasse o mapa de riscos, visto que a presença da presença do mapa de riscos dentro do documento era opcional. Dado o mapa de riscos, revisamos conforme conteúdos de aula para verificar a conformidade e veracidade das informações.

- **Prompt:** “Chat, gere um mapa de risco em formato de tabela de acordo com as normas anexadas e o cenário apresentado dizendo o risco que cada ativo possui e quais são os controles que devem ser aplicados para mitigar esses riscos.”

A.6 Sessões Introdutórias

A partir de um resumo criado com base na introdução, nas políticas e sobre nossos métodos de realizar o desenvolvimento do trabalho, solicitamos ao chatGPT que fizesse um texto descrevendo as seções de objetivos e a metodologia.

- **Prompt:** “Chat, baseado nos resumos informados previamente, criou dois parágrafos para as seções de "Metodologia " e "Objetivos" para a criação das políticas do cenário do Centro Hospitalar”.